

PLANTILLA P14 · EVALUACIÓN DE PROVEEDOR DE IA

Evaluación de proveedor de IA

Determina el nivel de exigencia de un proveedor de IA, evalúa su capacidad, sus garantías y la dependencia que genera, y comprueba que el contrato incluye las cláusulas clave.

EN ESTE DOCUMENTO

01 Instrucciones de uso

02 Identificación

03 Nivel de exigencia

04 Evaluación del proveedor

05 Cláusulas contractuales clave

06 Conclusión

07 Criterios de calidad

08 Aprobación y verificación

09 Control de versiones

Aviso legal y exención de responsabilidad. SEVEN-G es un marco metodológico de referencia que se ofrece «tal cual» y con fines exclusivamente informativos. No constituye asesoramiento jurídico, regulatorio, financiero ni profesional, ni garantiza el cumplimiento de ninguna norma. Las referencias a regulación general (como el Reglamento Europeo de IA, el RGPD, DORA o NIS2), a normas técnicas y a regulación específica de cada sector o jurisdicción pueden ser incompletas, no aplicar a un caso concreto o quedar desactualizadas por cambios normativos, interpretaciones o criterios de las autoridades posteriores a su fecha de consulta. **Cada organización que use SEVEN-G es la única responsable de identificar la normativa que le aplica, verificar su vigencia y certificar su propio cumplimiento regulatorio**, con el asesoramiento cualificado que corresponda. El autor y SEACHAD no asumen responsabilidad alguna por el uso que se haga de este contenido ni por las decisiones que se adopten con él. Los datos, cifras, compañías y casos de los ejemplos son ficticios o ilustrativos.

01

Instrucciones de uso

Aspecto	Indicación
Cuándo se usa	En la fase 3, antes de G3, para cada proveedor que aporte modelos, plataformas, datos o servicios de IA a la iniciativa. Se revisa antes de firmar o renovar el contrato, cuando el proveedor cambie de modelo o de condiciones, y con la periodicidad del nivel de exigencia.
Quién la rellena	El responsable técnico de IA, con compras y el responsable de riesgos de IA. Consulta a seguridad de la información, protección de datos y asesoría jurídica.
Quién la verifica	Lite: responsable de riesgos de IA; si ha elaborado la evaluación, verifica la oficina de IA o el auditor de IA. Enterprise: auditor de IA.
Quién decide	Se aprueba con G3: patrocinador con conformidad de riesgos (Lite) · comité de IA (Enterprise).
Gate en que se revisa	G3 · Viabilidad; comprobación de cláusulas firmadas en G5.
Herramienta	T09 · Registro de proveedores de IA.

Aspecto	Indicación
Lite frente a Enterprise	La profundidad depende del nivel de exigencia (N1, N2, N3), no solo de la intensidad. Lite puede omitir los campos marcados (Enterprise) si el proveedor es N1.

Reglas de cumplimentación:

- El nivel de exigencia se determina por el **factor más exigente**.
- Los requisitos por nivel de esta plantilla son **orientativos**; los definitivos se fijan en el documento 36.
- *Este documento no constituye asesoramiento jurídico*. Referencias consultadas en septiembre de 2026; debe verificarse su vigencia.

02

Identificación

Campo	Contenido	Guía
Código de la iniciativa	IA-AAAA-NNN.	
Sistemas de IA afectados	Códigos de P05.	
Proveedor	Razón social y país de establecimiento.	
Servicio o componente evaluado	Modelo por API, plataforma, software con IA embebida, datos, servicios profesionales.	
Opción de abastecimiento	Construir · Comprar · Aliarse.	
Versión del documento		
Fecha	DD-MM-AAAA.	
Autor	Nombre y rol.	

Nivel de exigencia

Factor	N1 Estándar	N2 Reforzado	N3 Crítico	Valoración
Criticidad del servicio	Apoyo a tareas internas no críticas	Proceso relevante o con exposición a clientes	Función crítica o importante, o sujeta a regulación de resiliencia operativa	N1 · N2 · N3
Datos tratados	Sin datos personales ni información confidencial	Datos personales o información confidencial	Categorías especiales, grandes volúmenes de datos personales o información confidencial crítica	
Autonomía	A0 Asistencia o A1 Recomendación	A2 Actuación supervisada	A3 Actuación autónoma	
Sustituibilidad	Sustituible en semanas sin impacto relevante	Sustituible con esfuerzo y coste significativos	Difícilmente sustituible en plazo razonable	

Campo	Contenido	Guía
Nivel de exigencia	N1 Estándar · N2 Reforzado · N3 Crítico. El más alto de los cuatro factores.	
Justificación		
Tercero TIC que presta servicios en funciones críticas o importantes (DORA)	Sí · No · No aplica. Solo entidades sujetas a DORA.	

(ejemplo ilustrativo) Proveedor de modelo de lenguaje por API para el asistente de consultas: criticidad N2 (exposición a clientes), datos N2 (datos personales de pedidos), autonomía N1 (A0), sustituibilidad N2. Nivel: **N2 Reforzado**.

Evaluación del proveedor

Resultado por bloque: **Conforme** · **Conforme con observaciones** · **No conforme** · **No evaluado**.

4.1 Capacidad y rendimiento

Campo	Contenido	Resultado	Guía
Rendimiento en el caso de uso			Resultados de pruebas propias con datos representativos (P10), no solo cifras del proveedor.
Documentación del modelo o servicio			Finalidad prevista, limitaciones conocidas, resultados de evaluación, instrucciones de uso.
Gestión de versiones y cambios			Preaviso de cambios de modelo, posibilidad de fijar versión, retirada de versiones.
Niveles de servicio			Disponibilidad, tiempos de respuesta, soporte.

4.2 Datos, privacidad y propiedad intelectual

Campo	Contenido	Resultado	Guía
Uso de los datos de la compañía			Si usa entradas, salidas o datos para entrenar o mejorar sus modelos; debe poder excluirse.
Condición de encargado del tratamiento			Contrato de encargo conforme al RGPD cuando trate datos personales por cuenta de la compañía.
Ubicación y transferencias internacionales			Países de tratamiento y garantías aplicables.
Subencargados y cadena de suministro			Lista, notificación de cambios y derecho de oposición.
Conservación y eliminación			Plazos y certificación de borrado.
Propiedad de los resultados y protección frente a reclamaciones			Titularidad de las salidas y compromisos del proveedor ante reclamaciones de terceros por propiedad intelectual.
Origen de los datos de entrenamiento (Enterprise)			Información disponible sobre licencias y procedencia.

4.3 Seguridad

Campo	Contenido	Resultado	Guía
Certificaciones e informes independientes			Por ejemplo, ISO/IEC 27001 o ISO/IEC 42001 , con alcance que cubra el servicio.
Controles específicos de IA			Protección frente a inyección de instrucciones, aislamiento entre clientes, filtrado de contenidos.
Gestión y notificación de incidentes			Plazos de notificación compatibles con las obligaciones de la compañía.
Identidad y acceso (Enterprise)			Autenticación, gestión de claves, registros de acceso.

4.4 Cumplimiento regulatorio

Campo	Contenido	Resultado	Guía
Rol del proveedor según el Reglamento Europeo de IA			Proveedor del sistema, proveedor de modelo de IA de uso general u otro.
Información que facilita para cumplir			Documentación e instrucciones que la compañía necesita según su propio rol (P11).
Compromiso de cumplimiento			Declaraciones y cooperación con la compañía y con las autoridades.
Requisitos sectoriales (Enterprise)			DORA , NIS2 u otra regulación aplicable a la compañía.

4.5 Dependencia, continuidad y salida

Campo	Contenido	Resultado	Guía
Concentración			Otros sistemas de la compañía que dependen del mismo proveedor (T09).
Portabilidad			Formatos de exportación de datos, configuraciones, instrucciones y registros.
Alternativas			Proveedores o soluciones alternativos identificados.

Campo	Contenido	Resultado	Guía
Solvencia y continuidad del proveedor (Enterprise)			Situación financiera, planes de continuidad, pruebas.
Plan de salida (Enterprise)			Pasos, plazo y coste de sustitución. Obligatorio en N3.

05

Cláusulas contractuales clave

Estado: **Incluida** · **En negociación** · **No incluida** · **No aplica**. Exigencia orientativa: **O** obligatoria · **R** recomendada · **—** no requerida.

#	Cláusula	Contenido mínimo	N1	N2	N3	Estado
1	Descripción del servicio y niveles de servicio	Alcance, disponibilidad, soporte, penalizaciones.	O	O	O	
2	Uso de datos	Prohibición o condiciones de uso de datos, entradas y salidas para entrenamiento o mejora.	O	O	O	
3	Protección de datos	Encargo del tratamiento, subencargados, transferencias, asistencia en derechos y evaluaciones.	O	O	O	
4	Confidencialidad	Alcance y duración.	O	O	O	
5	Seguridad	Controles mínimos, certificaciones y obligación de mantenerlos.	R	O	O	
6	Notificación de incidentes	Plazos, contenido y cooperación en la investigación.	R	O	O	
7	Cambios en el modelo o en el servicio	Preaviso, versiones fijas, derecho a resolver si el cambio afecta al cumplimiento o al rendimiento.	R	O	O	
8	Propiedad intelectual	Titularidad de resultados y protección frente a reclamaciones de terceros.	R	O	O	
9	Cumplimiento regulatorio	Información y cooperación para las obligaciones del Reglamento Europeo de IA y otra normativa.	R	O	O	
10	Auditoría y acceso	Derecho de auditoría, informes y acceso de supervisores cuando proceda.	—	R	O	

#	Cláusula	Contenido mínimo	N1	N2	N3	Estado
11	Subcontratación	Autorización, lista y responsabilidad del proveedor por sus subcontratistas.	—	R	O	
12	Ubicación del tratamiento	Países permitidos y notificación de cambios.	R	O	O	
13	Continuidad y resiliencia	Planes de continuidad y pruebas.	—	R	O	
14	Salida y reversibilidad	Devolución de datos, asistencia en la migración, periodo transitorio, borrado certificado.	R	O	O	
15	Responsabilidad y seguros	Límites de responsabilidad coherentes con el riesgo; seguros.	R	R	O	
16	Resolución	Causas, incluidos incumplimientos regulatorios o de seguridad.	O	O	O	

Para entidades sujetas a [DORA](#), los contratos con terceros proveedores de servicios TIC deben incluir las disposiciones contractuales clave que exige ese reglamento, reforzadas cuando el servicio soporta funciones críticas o importantes.

06

Conclusión

Campo	Contenido	Guía
Resultado global	Conforme · Conforme con observaciones · No conforme.	
Observaciones y condiciones	Qué debe resolverse, responsable y plazo (antes de firma o antes de G5).	
Riesgos para P12	Riesgos de categoría TER u otros identificados en la evaluación.	
Periodicidad de revisión	Orientativa: N1 cada dos años o al renovar; N2 anual; N3 anual y ante cualquier cambio relevante. El documento 36 fija la definitiva.	
Próxima revisión	Fecha.	

Un resultado **No conforme** en los bloques 4.2 o 4.3, o una cláusula obligatoria no incluida, impide usar el proveedor con datos de producción.

07

Criterios de calidad

Los criterios formales de G3 están en el documento 21 (ver criterios G3.xx) y los requisitos de terceros en el documento 36.

#	Comprobación	Estado
1	El nivel de exigencia está justificado con los cuatro factores.	Cumple · No cumple · No aplica · Pendiente
2	El rendimiento se ha comprobado con pruebas propias.	
3	El uso de datos por el proveedor está resuelto por contrato.	
4	Las cláusulas obligatorias del nivel están incluidas o en negociación con fecha anterior a G5.	
5	La dependencia y la salida están evaluadas; en N3 existe plan de salida.	
6	Los riesgos identificados se han trasladado a P12.	
7	El proveedor está registrado en T09 y en la ficha P05.	

08

Aprobación y verificación

Función	Rol en SEVEN-G	Nombre y cargo	Fecha	Firma o referencia
Elabora	Responsable técnico de IA			
Consultado	Compras · seguridad · protección de datos · asesoría jurídica			
Emite conformidad	Responsable de riesgos de IA			

Función	Rol en SEVEN-G	Nombre y cargo	Fecha	Firma o referencia
Verifica	Responsable de riesgos (Lite) · Auditor de IA (Enterprise)			
Decide	Patrocinador con conformidad de riesgos (Lite) · Comité de IA (Enterprise)			

Separación de funciones: quien negoció el contrato no verifica la evaluación; quien tenga conflicto de interés con el proveedor lo declara en P03.

09

Control de versiones

Documento cumplimentado

Versión	Fecha	Autor	Cambios
---------	-------	-------	---------

Plantilla

Versión	Fecha	Cambios
0.1	16-09-2026	Primera versión. Niveles de exigencia N1–N3 de la especificación común §5.6, evaluación por bloques y cláusulas contractuales clave. Requisitos por nivel orientativos hasta el documento 36.

Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo, de 14 de diciembre de 2022, relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión (Directiva SRI 2 / NIS2) · <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/spa> · Parlamento Europeo y Consejo de la UE · 14-12-2022

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos) · <https://eur-lex.europa.eu/eli/reg/2016/679/oj/spa> · Parlamento Europeo y Consejo de la UE · 27-04-2016

Reglamento (UE) 2022/2554 del Parlamento Europeo y del Consejo, de 14 de diciembre de 2022, sobre la resiliencia operativa digital del sector financiero (DORA) · <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/spa> · Parlamento Europeo y Consejo de la UE · 14-12-2022

Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas en materia de inteligencia artificial (Reglamento de Inteligencia Artificial) · <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/spa> · Parlamento Europeo y Consejo de la UE · 13-06-2024

ISO/IEC 27001:2022 Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de la seguridad de la información — Requisitos · <https://www.iso.org/standard/27001> · ISO/IEC (JTC 1/SC 27) · 25-10-2022
